

SOFTWARE SPECIFICATION DOCUMENT

FC237 CYBERSECURITY GOVERNANCE AND COMPLIANCE PLATFORM

Version 1.0

Project Title

FC237 Cybersecurity Governance and Compliance Platform for Secure Cloud Adoption among Small and Medium-Sized Enterprises in Cameroon

1. Introduction

1.1 Purpose of the Document

This Software Specification Document defines the functional, non-functional, technical, architectural, security, data, and usability requirements of the **FC237 Cybersecurity Governance and Compliance Platform**. The document serves as a development reference for designers, developers, testers, project supervisors, and future maintainers of the system.

The platform is designed to help small and medium-sized enterprises adopt cloud services securely by combining a localized cybersecurity governance and compliance framework with an interactive chatbot assistant. The system provides guided assessments, risk scoring, maturity evaluation, cloud vendor evaluation, compliance checklists, evidence tracking, incident-response guidance, and report generation.

1.2 Purpose of the Software

The purpose of the software is to transform the FC237 cybersecurity governance and compliance framework into a practical digital tool that SMEs can use without advanced cybersecurity knowledge.

The software helps SMEs to:

- understand cloud security responsibilities;

- assess their cloud security readiness;
- identify and score cloud-related risks;
- assess cybersecurity governance maturity;
- classify business and personal data;
- evaluate cloud service providers;
- receive recommended security controls;
- generate compliance checklists;
- record implementation evidence;
- receive incident-response guidance;
- generate compliance-readiness reports;
- improve cybersecurity maturity progressively.

1.3 Problem Statement

Many SMEs use cloud services such as email, cloud storage, cloud accounting, e-commerce platforms, online payment systems, cloud-hosted websites, and collaboration tools without a structured cybersecurity governance and compliance process. This exposes them to risks such as hacked cloud accounts, unauthorized access, phishing, ransomware, data leakage, poor backup practices, weak vendor evaluation, and non-compliance with data protection obligations.

Existing cybersecurity frameworks such as NIST CSF, ISO/IEC 27001, COBIT, CIS Controls, and CSA CCM are useful but often too complex, broad, expensive, or technical for direct SME implementation. Therefore, SMEs need a simplified, localized, guided, and practical system that helps them understand what to do, why it matters, and what evidence to keep.

The FC237 platform solves this problem by combining:

1. a localized cybersecurity governance and compliance framework;
2. a chatbot-based compliance assistant;
3. guided assessment tools;
4. risk and maturity scoring;
5. control recommendations;
6. evidence management;
7. compliance reporting.

1.4 Scope of the Software

The FC237 platform is a web-based cybersecurity governance and compliance assistant for SMEs. It focuses on cloud adoption security and compliance readiness. The system is not a penetration-testing tool, legal-advice platform, antivirus product, vulnerability scanner, or automated cloud security monitoring system.

The platform provides first-level cybersecurity and compliance guidance. It helps SMEs understand and implement basic controls, but it does not replace professional legal advice, formal audit, certified compliance assessment, or advanced cybersecurity consulting.

1.5 Intended Users

The intended users include:

- SME owners;
- SME managers;
- employees responsible for cloud tools;
- ICT or IT staff;
- external ICT consultants;
- cybersecurity consultants;
- compliance experts;
- system administrators;
- academic evaluators and supervisors.

1.6 Definitions

Term	Meaning
FC237	The proposed localized cybersecurity governance and compliance framework for SMEs in Cameroon.
SME	Small and medium-sized enterprise.
Compliance Assistant	The chatbot that guides users through FC237 implementation.
Cloud readiness	The degree to which an SME is prepared to adopt or use cloud services securely.
Risk score	A numerical value calculated using likelihood and impact.
Maturity level	A classification of the SME's cybersecurity governance maturity.
Compliance evidence	Records, screenshots, reports, logs, or documents proving that controls have been implemented.
Control	A security, governance, or compliance action used to reduce risk.
Vendor evaluation	The process of assessing a cloud provider before adoption.

2. System Overview

2.1 General Description

The FC237 Cybersecurity Governance and Compliance Platform is a web-based application that allows SMEs to interact with a compliance chatbot, complete cloud-readiness assessments,

evaluate security maturity, identify risks, receive recommendations, track evidence, and generate reports.

The system is structured around three major conceptual pillars:

1. **Governance**
2. **Compliance**
3. **Technical Controls**

These pillars are translated into software modules that guide users through practical steps.

2.2 Main System Components

The platform contains the following main components:

4. User authentication and account management
5. SME organization profile management
6. FC237 Compliance Assistant chatbot
7. Cloud-readiness assessment module
8. Risk scoring module
9. Maturity assessment module
10. Recommendation engine
11. Cloud vendor evaluation module
12. Compliance checklist module
13. Evidence management module
14. Incident-response guidance module
15. Report generation module
16. Dashboard and progress tracking
17. Knowledge base management module
18. Administrator dashboard

2.3 Main User Journey

The main user journey follows this sequence:

19. User registers or logs in.
20. User creates or joins an SME organization profile.
21. User starts a cloud-readiness assessment or asks the chatbot a question.
22. The platform collects information about cloud services, data types, access controls, backups, vendors, and incident practices.
23. The system calculates risk exposure and maturity level.
24. The recommendation engine generates prioritized controls.
25. The system generates a compliance checklist.
26. The user records implemented controls and uploads or records evidence.

27. The system generates a compliance-readiness report.
28. The user periodically reassesses and improves maturity.

2.4 High-Level Architecture

The system is organized into four layers:

Layer	Description
User Interface Layer	Web application, chatbot interface, dashboards, forms, reports.
Application Services Layer	Authentication, chatbot logic, assessments, scoring, recommendations, reporting.
Knowledge Layer	FC237 knowledge base, regulatory guidance, framework mappings, control rules.
Backend and Storage Layer	Convex backend, Convex database, secure file storage, audit logs.

3. System Objectives

3.1 General Objective

To provide a web-based cybersecurity governance and compliance platform that guides SMEs through secure cloud adoption using the FC237 Framework and an interactive compliance chatbot.

3.2 Specific Objectives

29. To help SMEs assess their cloud-security readiness.
30. To identify and score cybersecurity, governance, compliance, vendor, and operational risks.
31. To provide clear control recommendations based on FC237.
32. To help SMEs evaluate cloud service providers.
33. To support data classification and compliance evidence management.
34. To guide SMEs during basic cybersecurity incidents.
35. To generate compliance-readiness reports and improvement action plans.
36. To provide administrators and experts with tools for updating the FC237 knowledge base.

4. User Roles and Permissions

4.1 SME User

The SME User represents an owner, manager, employee, or staff member responsible for cloud tools.

Permissions

The SME User can:

- register and log in;
- create or join an SME profile;
- ask chatbot questions;
- complete assessments;
- identify cloud services;
- classify data;
- score risks;
- view recommendations;
- generate checklists;
- record implemented controls;
- upload or record evidence;
- evaluate vendors;
- request incident guidance;
- generate reports;
- view dashboards.

4.2 Cyber Focal Point

The Cyber Focal Point is a more responsible SME user, such as an IT staff member, external technician, or trusted employee.

Permissions

The Cyber Focal Point can:

- perform all SME User actions;
- manage cloud inventories;
- manage security controls;
- update implementation status;
- review evidence;
- manage incident records;
- generate organization-level reports.

4.3 Organization Owner or Manager

The Organization Owner or Manager is responsible for business-level accountability.

Permissions

The Owner or Manager can:

- create SME organization profile;
- invite users;
- assign roles;
- approve assessments;
- view organization dashboard;
- download reports;
- approve risk treatment actions;
- view evidence summaries.

4.4 Compliance Expert

The Compliance Expert supports the quality of the compliance guidance.

Permissions

The Compliance Expert can:

- review FC237 knowledge base content;
- suggest updates to compliance guidance;
- review regulatory mappings;
- validate control descriptions;
- provide expert comments;
- review anonymized assessment logic.

4.5 System Administrator

The System Administrator manages the platform.

Permissions

The System Administrator can:

- manage users;
- manage organizations;
- manage access rights;
- update knowledge base entries;
- approve expert updates;
- monitor platform usage;
- view system logs;
- manage application settings;
- manage report templates;
- manage backup and maintenance operations.

5. Functional Requirements

5.1 Authentication and User Management

FR-AUTH-01: User Registration

The system shall allow users to create an account using name, email address, password, and role.

FR-AUTH-02: User Login

The system shall allow registered users to log in securely.

FR-AUTH-03: Password Security

The system shall store user passwords using secure password hashing and shall not store plain-text passwords.

FR-AUTH-04: Role-Based Access Control

The system shall restrict features based on user role.

FR-AUTH-05: Session Management

The system shall manage user sessions securely and automatically expire inactive sessions.

FR-AUTH-06: User Profile Management

The system shall allow users to update their basic profile information.

FR-AUTH-07: Organization Invitation

The system shall allow organization owners or administrators to invite users to join an SME organization profile.

5.2 SME Organization Profile Management

FR-ORG-01: Create SME Profile

The system shall allow users to create an SME organization profile.

FR-ORG-02: Store Organization Information

The system shall store:

- organization name;
- sector;
- location;
- number of employees;
- ICT support status;

- cloud usage status;
- assigned risk owner;
- assigned cyber focal point.

FR-ORG-03: Update Organization Profile

The system shall allow authorized users to update SME profile information.

FR-ORG-04: Organization Dashboard

The system shall provide a dashboard showing:

- readiness score;
- maturity level;
- number of identified risks;
- number of implemented controls;
- pending evidence;
- generated reports;
- next review date.

5.3 FC237 Compliance Assistant Chatbot

FR-CHAT-01: Ask Question

The system shall allow users to ask cybersecurity, cloud security, and compliance-related questions.

FR-CHAT-02: Identify User Intent

The chatbot shall classify user requests into predefined intents such as:

- cloud storage security;
- cloud email security;
- MFA guidance;
- backup guidance;
- access review;
- employee offboarding;
- vendor evaluation;
- data classification;
- incident response;
- compliance evidence;
- maturity assessment;
- cloud readiness.

FR-CHAT-03: Ask Clarifying Questions

If the user's request is unclear, the chatbot shall ask follow-up questions before generating recommendations.

FR-CHAT-04: Retrieve FC237 Guidance

The chatbot shall retrieve relevant guidance from the FC237 knowledge base.

FR-CHAT-05: Generate Structured Recommendations

The chatbot shall provide responses organized into:

- risk identified;
- recommended action;
- priority level;
- evidence to keep;
- next step.

FR-CHAT-06: Escalation Notice

The chatbot shall advise users to contact a cybersecurity expert, legal professional, or cloud provider when the issue exceeds first-level guidance.

FR-CHAT-07: Save Chat History

The system shall save chat interactions for continuity and reporting, subject to user privacy settings.

FR-CHAT-08: Avoid Sensitive Data Collection

The chatbot shall not request passwords, financial credentials, customer records, private keys, or confidential system secrets.

5.4 Cloud Readiness Assessment

FR-READ-01: Start Assessment

The system shall allow users to start a cloud-readiness assessment.

FR-READ-02: Assessment Questions

The system shall ask questions about:

- cloud services used;
- cloud inventory;
- data stored in cloud services;
- MFA usage;

- password practices;
- access review;
- backup practices;
- vendor evaluation;
- incident response;
- compliance evidence.

FR-READ-03: Save Assessment Progress

The system shall allow users to save and continue assessments later.

FR-READ-04: Calculate Readiness Score

The system shall calculate a readiness score based on user responses.

FR-READ-05: Readiness Classification

The system shall classify readiness as:

- Not ready;
- Partially ready;
- Ready with improvements;
- Cloud-ready.

FR-READ-06: Readiness Recommendations

The system shall recommend improvement actions based on assessment gaps.

5.5 Risk Scoring Module

FR-RISK-01: Identify Risk

The system shall allow users to identify cloud-related risks.

FR-RISK-02: Risk Categories

The system shall classify risks into:

- technical risks;
- governance risks;
- compliance risks;
- vendor risks;
- human and operational risks.

FR-RISK-03: Likelihood Scoring

The system shall allow users to assign a likelihood score from 1 to 5.

FR-RISK-04: Impact Scoring

The system shall allow users to assign an impact score from 1 to 5.

FR-RISK-05: Risk Score Calculation

The system shall calculate risk score using:

Risk Score = Likelihood × Impact

FR-RISK-06: Risk Level Assignment

The system shall classify risk as:

Risk score	Risk level
1–5	Low
6–10	Moderate
11–15	High
16–25	Critical

FR-RISK-07: Risk Treatment Recommendation

The system shall recommend treatment actions based on the risk level.

FR-RISK-08: Risk Register

The system shall maintain a risk register for each SME organization.

5.6 Maturity Assessment Module

FR-MAT-01: Assess Maturity

The system shall assess the SME's cybersecurity governance maturity.

FR-MAT-02: Maturity Categories

The system shall evaluate maturity across:

- governance maturity;
- technical control maturity;
- compliance readiness;
- vendor readiness;
- incident preparedness.

FR-MAT-03: Assign Maturity Level

The system shall assign one of five maturity levels:

Level	Status
--------------	---------------

- Level
1 Ad hoc
- Level
2 Basic
- Level
3 Defined
- Level
4 Managed
- Level
5 Optimized

FR-MAT-04: Maturity Improvement Plan

The system shall generate recommendations for moving to the next maturity level.

5.7 Recommendation Engine

FR-REC-01: Generate Control Recommendations

The system shall recommend security controls based on assessment results, risk scores, and maturity level.

FR-REC-02: Prioritize Recommendations

The system shall classify recommendations as:

- urgent;
- high priority;
- medium priority;
- long-term improvement.

FR-REC-03: Map Recommendations to FC237 Pillars

Each recommendation shall be mapped to one FC237 pillar:

- governance;
- compliance;
- technical controls.

FR-REC-04: Provide Evidence Requirements

Each recommendation shall identify the evidence that the SME should keep after implementation.

FR-REC-05: Provide Plain-Language Explanation

The system shall explain each recommendation in simple language suitable for non-technical SME users.

5.8 Vendor Evaluation Module

FR-VEN-01: Start Vendor Evaluation

The system shall allow users to evaluate a cloud provider.

FR-VEN-02: Vendor Evaluation Criteria

The system shall evaluate vendors using criteria such as:

- MFA support;
- encryption;
- backup and recovery;
- data location;
- service availability;
- support quality;
- data export;
- data deletion;
- contract clarity;
- pricing transparency;
- compliance documentation.

FR-VEN-03: Vendor Scoring

The system shall calculate a vendor score based on user responses.

FR-VEN-04: Vendor Recommendation

The system shall classify vendor suitability as:

- weak provider fit;
- moderate provider fit;
- good provider fit;
- strong provider fit.

FR-VEN-05: Vendor Evidence

The system shall advise users to keep vendor-related evidence such as contracts, SLA information, data-processing terms, security documentation, and support records.

5.9 Data Classification Module

FR-DATA-01: Identify Data Assets

The system shall allow users to list data stored or processed in cloud services.

FR-DATA-02: Classify Data

The system shall allow data to be classified as:

- public;
- internal;
- confidential;
- personal;
- critical.

FR-DATA-03: Recommend Protection Level

The system shall recommend security actions based on data classification.

FR-DATA-04: Link Data to Cloud Services

The system shall link data assets to the cloud services where they are stored or processed.

FR-DATA-05: Retention Guidance

The system shall provide basic retention and deletion guidance for different data categories.

5.10 Compliance Checklist Module

FR-CHECK-01: Generate Checklist

The system shall generate compliance checklists based on assessment findings.

FR-CHECK-02: Checklist Categories

The checklist shall include items related to:

- cloud inventory;
- MFA;
- access review;
- data classification;
- backup;
- vendor evaluation;
- offboarding;
- incident response;
- evidence records;
- staff awareness.

FR-CHECK-03: Mark Checklist Items

The system shall allow users to mark checklist items as:

- not started;

- in progress;
- implemented;
- not applicable.

FR-CHECK-04: Track Checklist Completion

The system shall calculate checklist completion percentage.

5.11 Compliance Evidence Management

FR-EVID-01: Record Evidence

The system shall allow users to record compliance evidence.

FR-EVID-02: Upload Evidence

The system shall allow users to upload supporting evidence files where necessary.

FR-EVID-03: Evidence Types

The system shall support evidence types such as:

- MFA screenshot;
- access review sheet;
- backup log;
- vendor evaluation form;
- incident log;
- data classification table;
- offboarding checklist;
- staff training record;
- generated report.

FR-EVID-04: Evidence Metadata

The system shall store evidence metadata including:

- evidence title;
- evidence type;
- upload date;
- related control;
- related user;
- status;
- review notes.

FR-EVID-05: Evidence Status

Evidence shall have one of the following statuses:

- pending;
- submitted;
- accepted;
- rejected;
- expired.

FR-EVID-06: Evidence Access Control

Only authorized users shall access evidence linked to their organization.

5.12 Incident-Response Guidance Module

FR-INC-01: Request Incident Guidance

The system shall allow users to request guidance for common cybersecurity incidents.

FR-INC-02: Incident Categories

The system shall support guidance for:

- phishing;
- suspicious login;
- hacked cloud account;
- hacked email account;
- ransomware;
- lost or stolen device;
- data leakage;
- former employee access;
- accidental file deletion;
- website compromise.

FR-INC-03: Provide Immediate Steps

The system shall provide first-response steps such as:

- disconnect affected device;
- change password;
- enable MFA;
- revoke suspicious sessions;
- contact provider;
- preserve screenshots;
- record time of incident;
- notify responsible person;
- restore from backup.

FR-INC-04: Incident Record

The system shall allow users to record incidents and response actions.

FR-INC-05: Escalation Recommendation

The system shall recommend escalation for high-risk or legally sensitive incidents.

5.13 Report Generation Module

FR-REP-01: Generate Readiness Report

The system shall generate a cloud-readiness report.

FR-REP-02: Generate Risk Report

The system shall generate a risk assessment report.

FR-REP-03: Generate Maturity Report

The system shall generate a maturity assessment report.

FR-REP-04: Generate Compliance Summary

The system shall generate a compliance-readiness summary.

FR-REP-05: Generate Action Plan

The system shall generate a prioritized improvement action plan.

FR-REP-06: Export Report

The system shall allow reports to be exported as PDF.

FR-REP-07: Report Content

Reports shall include:

- SME profile;
- cloud services;
- data classifications;
- risk scores;
- maturity level;
- recommended controls;
- evidence requirements;
- checklist completion;
- next review date.

5.14 Dashboard and Progress Tracking

FR-DASH-01: Organization Dashboard

The system shall provide a dashboard for each SME organization.

FR-DASH-02: Dashboard Metrics

The dashboard shall show:

- readiness score;
- maturity level;
- number of risks;
- number of high and critical risks;
- number of implemented controls;
- checklist completion rate;
- pending evidence;
- latest report;
- upcoming review.

FR-DASH-03: Visual Indicators

The system shall use visual indicators for risk levels, maturity levels, and control implementation progress.

5.15 Knowledge Base Management

FR-KB-01: Store FC237 Guidance

The system shall store structured guidance from the FC237 Framework.

FR-KB-02: Store Control Mappings

The system shall store mappings between FC237 controls and international frameworks.

FR-KB-03: Store Regulatory Guidance

The system shall store summarized regulatory guidance relevant to cybersecurity, electronic commerce, and personal data protection.

FR-KB-04: Admin Updates

Authorized administrators shall update knowledge base content.

FR-KB-05: Expert Review

Compliance experts shall be able to review or suggest updates to knowledge base entries.

FR-KB-06: Version Control

The system should maintain versions of knowledge base updates.

6. Key Features

6.1 FC237 Compliance Assistant Chatbot

The chatbot is the main user-facing feature. It guides SMEs using natural, simple questions and answers. It converts cybersecurity and compliance concepts into practical recommendations.

Key capabilities include:

- question answering;
- guided assessments;
- contextual recommendations;
- incident guidance;
- compliance evidence explanation;
- cloud security education;
- plain-language explanations;
- escalation notices.

6.2 Guided Cloud-Readiness Assessment

This feature helps SMEs understand whether they are ready to adopt cloud services securely.

It checks:

- whether cloud services are known;
- whether sensitive data is identified;
- whether MFA is enabled;
- whether backups exist;
- whether access is reviewed;
- whether vendors are evaluated;
- whether incidents are documented;
- whether evidence is retained.

6.3 Risk Scoring

The system allows SMEs to score risks using likelihood and impact. This helps non-expert users prioritize action.

6.4 Maturity Assessment

The maturity assessment helps SMEs understand their current cybersecurity governance position and what they need to improve next.

6.5 Control Recommendation

The system recommends practical controls based on user responses. Examples include:

- enable MFA;
- review user access;
- classify data;
- restrict file sharing;
- remove former employees;
- back up critical data;
- evaluate vendors;
- keep evidence;
- document incidents.

6.6 Vendor Evaluation

The vendor evaluation module helps SMEs avoid selecting cloud providers based only on price or popularity. It introduces security, availability, compliance, support, and data portability considerations.

6.7 Compliance Evidence Register

The evidence register helps SMEs prove that they have implemented controls. It supports accountability and compliance readiness.

6.8 Compliance Reports

The reporting module produces structured reports that SMEs can use for internal review, supervisor demonstration, academic validation, or future compliance preparation.

6.9 Administrator Knowledge Base

The knowledge base allows the system to remain maintainable. As laws, controls, threats, or framework mappings evolve, administrators can update the system without rebuilding the entire application.

7. Non-Functional Requirements

7.1 Usability

The system shall be simple enough for non-technical SME users.

Usability requirements include:

- simple language;
- clear buttons;
- minimal technical jargon;
- mobile-friendly interface;
- guided workflows;
- short explanations;
- clear next steps;
- visible progress indicators.

7.2 Performance

The system should respond quickly to user actions.

Performance targets:

Function	Expected response time
Page loading	Under 3 seconds
Chatbot response	Under 5 seconds
Assessment submission	Under 5 seconds
Report generation	Under 10 seconds
Dashboard loading	Under 5 seconds

7.3 Security

The system shall protect user accounts, organizational data, assessment responses, reports, and evidence metadata.

Security requirements include:

- HTTPS;
- secure authentication;
- password hashing;
- role-based access control;
- organization-level data separation;

- secure file access;
- audit logging;
- input validation;
- protection against unauthorized access;
- secure database rules;
- limited administrator privileges.

7.4 Privacy

The system shall minimize the collection of sensitive business data.

Privacy requirements include:

- do not request passwords;
- do not request financial credentials;
- do not collect customer records unnecessarily;
- collect only what is needed for assessment;
- allow users to delete or export their records where feasible;
- protect chat history and evidence metadata;
- separate each organization's data.

7.5 Reliability

The system shall remain stable during normal use.

Reliability requirements include:

- error handling;
- backup of database records;
- prevention of data loss during assessment;
- recovery from failed report generation;
- clear user messages when errors occur.

7.6 Maintainability

The system shall be easy to update and extend.

Maintainability requirements include:

- modular architecture;
- reusable components;
- structured knowledge base;
- clear naming conventions;
- documented backend functions;
- versioned control mappings;

- separation between UI, logic, and data.

7.7 Scalability

The system should support growth in:

- number of SME users;
- number of organizations;
- number of assessments;
- number of evidence records;
- number of knowledge base entries;
- number of generated reports.

7.8 Accessibility

The system should be usable by people with different levels of digital literacy.

Accessibility requirements include:

- readable font sizes;
- high contrast;
- clear labels;
- mobile responsiveness;
- keyboard-friendly navigation where possible;
- simple form structure.

7.9 Compatibility

The system shall support modern browsers such as:

- Google Chrome;
- Microsoft Edge;
- Mozilla Firefox;
- Safari.

The interface should support both desktop and mobile screens.

8. System Architecture

8.1 Presentation Layer

The presentation layer contains:

- web application;

- chatbot interface;
- assessment dashboard;
- compliance progress dashboard;
- report viewer;
- administrator dashboard.

Recommended technology:

- Next.js;
- React;
- Tailwind CSS or equivalent styling framework.

8.2 Application Services Layer

The application services layer contains:

- authentication service;
- chatbot service;
- cloud-readiness assessment module;
- risk scoring module;
- maturity assessment module;
- recommendation engine;
- vendor evaluation module;
- evidence management module;
- incident-response guidance module;
- report generation module.

8.3 Knowledge Layer

The knowledge layer contains:

- FC237 knowledge base;
- governance guidance;
- compliance guidance;
- technical control guidance;
- regulatory guidance repository;
- framework control mapping repository;
- frequently asked questions;
- incident-response templates.

8.4 Backend and Storage Layer

The backend and storage layer contains:

- Convex backend functions;
- Convex database;
- secure file storage;
- audit logs;
- report metadata;
- organization data;
- user records;
- chat history;
- evidence metadata.

8.5 External Services

Possible external services include:

- authentication provider;
- email notification provider;
- AI model provider;
- secure file storage provider;
- PDF generation service.

9. Data Requirements

9.1 Main Data Entities

The system shall manage the following data entities:

1. User
2. SME Organization
3. Cloud Service
4. Data Asset
5. Risk Assessment
6. Risk
7. Security Control
8. Compliance Evidence
9. Vendor Evaluation
10. Chat Session
11. Chat Message
12. Compliance Checklist
13. Checklist Item
14. Incident
15. Compliance Report

- 16. Knowledge Base Entry
- 17. Audit Log

9.2 User Entity

Field	Type	Description
userId	UUID	Unique user identifier
fullName	String	User's full name
email	String	User email
passwordHash	String	Secure password hash
role	String	User role
organizationId	UUID	Linked SME organization
createdAt	DateTime	Account creation date

9.3 SME Organization Entity

Field	Type	Description
organizationId	UUID	Unique organization identifier
name	String	Enterprise name
sector	String	Business sector
location	String	City or region
sizeCategory	String	Number of employees category
ictSupportStatus	String	ICT support availability
readinessScore	Number	Cloud readiness score
maturityLevel	Number	Maturity level
createdAt	DateTime	Profile creation date

9.4 Cloud Service Entity

Field	Type	Description
cloudServiceId	UUID	Unique cloud service identifier
organizationId	UUID	Linked organization
serviceName	String	Name of service
providerName	String	Cloud provider
serviceModel	String	SaaS, PaaS, IaaS
purpose	String	Business use
dataStored	String	Type of data stored
approved	Boolean	Approval status

9.5 Risk Assessment Entity

Field	Type	Description
-------	------	-------------

assessmentId	UUID	Unique assessment identifier
organizationId	UUID	Linked organization
riskTitle	String	Risk name
riskCategory	String	Risk category
likelihood	Number	Likelihood score
impact	Number	Impact score
riskScore	Number	Likelihood × impact
riskLevel	String	Low, moderate, high, critical
treatmentStatus	String	Status of treatment

9.6 Security Control Entity

Field	Type	Description
controlId	UUID	Unique control identifier
name	String	Control name
description	String	Control description
pillar	String	Governance, compliance, or technical
priority	String	Control priority
implementationStatus	String	Not started, in progress, implemented
evidenceRequired	Boolean	Whether evidence is required

9.7 Compliance Evidence Entity

Field	Type	Description
evidenceId	UUID	Unique evidence identifier
organizationId	UUID	Linked organization
controlId	UUID	Linked control
evidenceType	String	Type of evidence
fileReference	String	File path or storage reference
status	String	Pending, submitted, accepted, rejected
uploadedAt	DateTime	Date uploaded
notes	String	Review notes

9.8 Chat Message Entity

Field	Type	Description
messageId	UUID	Unique message identifier
sessionId	UUID	Linked chat session

senderType	String	User or assistant
content	String	Message content
detectedIntent	String	Identified intent
timestamp	DateTime	Message time

9.9 Report Entity

Field	Type	Description
reportId	UUID	Unique report identifier
organizationId	UUID	Linked organization
reportType	String	Readiness, risk, maturity, compliance
generatedAt	DateTime	Generation date
reportUrl	String	PDF file reference
readinessScore	Number	Readiness score
maturityLevel	Number	Maturity level

10. User Interface Requirements

10.1 General UI Principles

The interface shall be:

- simple;
- modern;
- clean;
- mobile-friendly;
- suitable for non-technical users;
- consistent in typography and layout;
- guided rather than overwhelming.

10.2 Main Pages

The platform shall include:

1. Landing page
2. Registration page
3. Login page
4. SME profile setup page
5. Main dashboard
6. Chatbot assistant page
7. Cloud-readiness assessment page
8. Risk assessment page

9. Maturity assessment page
10. Vendor evaluation page
11. Compliance checklist page
12. Evidence management page
13. Incident guidance page
14. Report viewer page
15. Admin dashboard
16. Knowledge base management page

10.3 Dashboard Requirements

The dashboard shall display:

- organization name;
- readiness score;
- maturity level;
- number of risks;
- high and critical risks;
- implemented controls;
- pending evidence;
- checklist completion;
- generated reports;
- recommended next action.

10.4 Chatbot Interface Requirements

The chatbot page shall include:

- message input field;
- conversation history;
- suggested question buttons;
- assessment shortcut buttons;
- recommendation cards;
- evidence requirement cards;
- report generation shortcut.

10.5 Assessment Interface Requirements

Assessment pages shall include:

- progress indicator;
- simple questions;
- multiple-choice responses;

- save and continue option;
- back and next buttons;
- summary before submission.

10.6 Report Viewer Requirements

The report viewer shall allow users to:

- view report summary;
- download PDF;
- view recommendations;
- view evidence requirements;
- view maturity level;
- view next review date.

11. AI and Chatbot Specification

11.1 Chatbot Type

The chatbot shall be knowledge-base-driven and may use rule-based, retrieval-based, or LLM-assisted logic.

For the prototype, the recommended approach is:

- rule-based intent recognition;
- structured FC237 knowledge base;
- templated recommendations;
- optional LLM-assisted explanation layer.

11.2 Chatbot Intent Categories

The chatbot shall recognize intents including:

Intent	Example user question
Cloud storage security	How do I secure Google Drive?
Cloud email security	How do I protect my company email?
MFA guidance	Do I need MFA?
Backup guidance	How should I back up cloud files?
Vendor evaluation	How do I know if a cloud provider is safe?
Data classification	What data should I protect most?
Offboarding	What should I do when an employee leaves?

Incident response What should I do after a suspicious login?

Compliance evidence What records should I keep?

Maturity assessment How mature is my cloud security?

11.3 Chatbot Response Format

A standard chatbot response should include:

1. brief explanation;
2. identified risk;
3. recommended actions;
4. priority level;
5. evidence to keep;
6. next step;
7. escalation notice if necessary.

11.4 Chatbot Safety Rules

The chatbot shall not:

- request passwords;
- request private keys;
- request customer databases;
- request financial credentials;
- provide illegal advice;
- claim to replace legal counsel;
- claim to perform formal audit;
- guarantee compliance;
- generate false legal certainty;
- encourage unsafe security practices.

11.5 Escalation Conditions

The chatbot shall recommend expert support when:

- personal data breach is suspected;
- ransomware is active;
- business-critical systems are unavailable;
- legal obligations are unclear;
- customer data has leaked;
- payment fraud occurred;
- cloud account compromise is confirmed;
- the user asks for formal compliance certification.

12. Security Specification

12.1 Authentication Security

The system shall use secure login mechanisms and protect credentials.

12.2 Authorization Security

The system shall enforce role-based access control.

12.3 Organization-Level Data Separation

Users shall access only data belonging to their assigned organization.

12.4 Secure File Access

Evidence files shall be accessible only to authorized users.

12.5 Audit Logging

The system shall log important actions such as:

- login attempts;
- assessment submissions;
- evidence uploads;
- report generation;
- role changes;
- knowledge base updates.

12.6 Input Validation

The system shall validate user inputs to reduce injection, malformed data, and storage errors.

12.7 Data Minimization

The system shall collect only information necessary for cybersecurity and compliance assessment.

12.8 Backup and Recovery

The system should support backup and recovery of critical platform data.

13. Reporting Specification

13.1 Report Types

The platform shall generate the following reports:

1. Cloud-readiness report
2. Risk assessment report
3. Maturity assessment report
4. Vendor evaluation report
5. Compliance checklist report
6. Compliance-readiness summary
7. Improvement action plan

13.2 Report Sections

A complete compliance-readiness report shall include:

- title;
- organization information;
- date generated;
- readiness score;
- maturity level;
- cloud services identified;
- sensitive data categories;
- major risks;
- recommended controls;
- pending evidence;
- completed checklist items;
- next review date;
- disclaimer.

13.3 Report Disclaimer

Each report shall include the following disclaimer:

“This report provides first-level cybersecurity governance and compliance guidance based on the FC237 Framework. It does not replace legal advice, formal audit, penetration testing, or professional cybersecurity assessment.”

14. Testing Requirements

14.1 Functional Testing

The system shall be tested to confirm that each module works correctly.

Example test cases:

Test case	Expected result
User registers	Account is created successfully
User logs in	Dashboard opens
User asks chatbot about MFA	Chatbot returns MFA guidance
User completes readiness assessment	Readiness score is generated
User scores a risk	Risk level is calculated
User evaluates vendor	Vendor score is generated
User uploads evidence	Evidence metadata is saved
User generates report	PDF report is created

14.2 Usability Testing

The system shall be tested with representative SME users to evaluate:

- clarity;
- ease of use;
- navigation;
- understanding of recommendations;
- usefulness of chatbot;
- simplicity of reports;
- confidence in next steps.

14.3 Security Testing

Security testing should include:

- authentication testing;
- authorization testing;
- invalid input testing;
- file upload testing;
- session timeout testing;
- organization data isolation testing.

14.4 Performance Testing

Performance testing should verify:

- page load speed;
- chatbot response speed;
- report generation time;
- assessment submission time;
- dashboard rendering time.

14.5 Acceptance Testing

The platform shall be considered acceptable if:

- users can complete the main journey without assistance;
- chatbot gives relevant recommendations;
- risk scoring works correctly;
- maturity level is assigned correctly;
- reports are generated successfully;
- evidence can be recorded;
- users understand recommended actions.

15. Functional Acceptance Criteria

15.1 Authentication

The system passes authentication acceptance if users can register, log in, log out, and access role-appropriate features.

15.2 Chatbot

The system passes chatbot acceptance if it can answer common SME cloud-security questions using FC237 guidance.

15.3 Assessment

The system passes assessment acceptance if it can collect user answers, compute readiness, identify weaknesses, and produce recommendations.

15.4 Risk Scoring

The system passes risk scoring acceptance if it correctly calculates likelihood multiplied by impact and assigns the proper risk level.

15.5 Maturity Assessment

The system passes maturity acceptance if it assigns maturity level based on assessment answers and gives improvement actions.

15.6 Evidence Management

The system passes evidence acceptance if users can record or upload evidence and link it to controls.

15.7 Reporting

The system passes reporting acceptance if it can generate a readable compliance-readiness report.

16. Constraints

16.1 Technical Constraints

The system is constrained by:

- available development time;
- prototype-level implementation;
- dependence on Convex backend;
- possible file storage limitations;
- limited user testing;
- limited availability of real compliance experts.

16.2 Functional Constraints

The system does not:

- automatically scan cloud accounts;
- perform vulnerability assessment;
- conduct penetration testing;
- guarantee legal compliance;
- replace auditors;
- replace cybersecurity consultants;
- directly enforce controls in external cloud platforms.

16.3 Data Constraints

The system should not collect:

- passwords;
- secret keys;
- complete customer databases;
- financial credentials;
- confidential contracts unless required and authorized;
- sensitive medical or student records.

17. Assumptions

The specification assumes that:

- users have basic internet access;
- users can access the platform through a browser;
- SMEs are willing to answer assessment questions honestly;
- the FC237 knowledge base will be maintained;
- administrators will review regulatory updates;
- the prototype will be tested before final defense;
- reports will be used as guidance, not formal certification.

18. Risks and Mitigation

Risk	Description	Mitigation
User misunderstands chatbot guidance	Non-technical users may misinterpret recommendations	Use simple language and examples
Outdated compliance guidance	Laws and regulations may evolve	Maintain updateable knowledge base
Overreliance on chatbot	Users may treat chatbot as legal authority	Include disclaimer and escalation notices
Weak evidence security	Uploaded files may contain sensitive information	Use access control and secure storage
Poor adoption	SMEs may not use the system consistently	Provide simple dashboard and clear benefits
Incomplete assessments	Users may abandon long forms	Use short guided workflows
Incorrect user input	Recommendations depend on user answers	Allow review and update of responses

19. Future Enhancements

Future versions may include:

- bilingual English and French interface;

- local-language support;
- AI-assisted report explanation;
- automated reminder notifications;
- cloud provider API integration;
- automated evidence collection;
- sector-specific templates;
- downloadable policy templates;
- real-time risk dashboard;
- expert consultation marketplace;
- mobile application;
- offline assessment mode;
- improved analytics;
- benchmarking between SMEs;
- regulatory update alerts;
- integration with email and collaboration platforms.

20. Minimum Viable Product

The MVP should include:

1. user registration and login;
2. SME organization profile;
3. chatbot guidance module;
4. cloud-readiness assessment;
5. risk scoring;
6. maturity assessment;
7. control recommendations;
8. compliance checklist;
9. vendor evaluation;
10. evidence recording;
11. report generation;
12. administrator knowledge base management.

21. Final Deliverables

The final software project should include:

- source code;
- database schema;
- frontend interface;

- backend functions;
- FC237 knowledge base;
- chatbot workflows;
- assessment module;
- risk scoring module;
- maturity assessment module;
- vendor evaluation module;
- evidence management module;
- report generation module;
- UML diagrams;
- software architecture diagram;
- deployment diagram;
- test cases;
- screenshots;
- user guide;
- technical documentation.

22. Conclusion

The FC237 Cybersecurity Governance and Compliance Platform is designed to make secure cloud adoption more practical for SMEs. It transforms the FC237 Framework into a usable software system that guides users through assessment, risk identification, maturity evaluation, control recommendation, evidence management, vendor evaluation, incident response, and reporting.

The platform's key contribution is not only technical implementation but also usability. It reduces the complexity of cybersecurity governance by presenting SMEs with simple questions, practical recommendations, and clear evidence requirements. Through the FC237 Compliance Assistant, the platform provides a structured pathway from informal cloud usage toward more secure, accountable, and compliance-ready cloud adoption.